

SIMATS ENGINEERING

ASSESSMENT TOOL 2 – APPLICATION-BASED QUESTIONS (High)

Course: ETHICAL HACKING	Code: ITA1407	CO: CO5
Duration:	Total Marks: 100	Reg No / Name : Y.HEMA SAI LAHARI(192311446)

COURSE OUTCOME COVERED

CO5: *Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools. (BT5)*

Instructions: Answer all questions. Each question carries 20 marks.

1. A mid-sized financial organization operates several legacy Windows servers where multiple RPC services remain exposed due to delayed patching cycles caused by operational constraints. Recently, abnormal traffic patterns and unauthorized connection attempts have been observed within the internal network. As a security analyst, evaluate how attackers could exploit these RPC vulnerabilities to gain unauthorized access and escalate privileges. Assess the level of risk associated with delaying patches in such environments and justify whether immediate patch deployment or controlled maintenance scheduling is more appropriate. Recommend suitable mitigation strategies to reduce exposure without affecting business continuity.

2. A web application used for online transactions suffers from multiple vulnerabilities, including cross-site scripting (XSS), cross-site request forgery (CSRF), and weak session management practices. Users report unauthorized transactions and session hijacking incidents. Evaluate how attackers could combine these vulnerabilities to execute complex attacks affecting user accounts. Assess the risks associated with poor session handling and lack of input validation. Justify the need for a layered security approach and recommend comprehensive mitigation strategies to secure the application.

3. An enterprise uses an outdated IIS server to host multiple internal and external applications, and recent vulnerability scans indicate several unpatched critical flaws. Despite warnings, the organization delays updates due to fear of downtime and service disruption. Assess how attackers could exploit these vulnerabilities to gain unauthorized access or execute remote code. Evaluate the risks associated with delaying security updates in such

environments and justify whether immediate patching or temporary isolation is more appropriate. Recommend strategies to ensure both security and service availability.

4. A mobile application used by customers stores sensitive information such as login credentials and personal data in plaintext within the device storage. Additionally, the application communicates with backend servers over unsecured channels. Evaluate how attackers could exploit these weaknesses through device compromise or network interception. Assess the potential impact on user privacy and organizational reputation. Justify the need for encryption and recommend secure storage and communication techniques.

5. A system administrator disables the Windows firewall temporarily to troubleshoot connectivity issues but forgets to re-enable it. Within a short period, multiple unauthorized access attempts are detected. Evaluate how attackers could exploit this temporary exposure to gain access to critical services. Assess the risks associated with mismanagement of security controls and justify the importance of enforcing automated policies. Recommend administrative safeguards to prevent such incidents.

Code of Conduct:

I Y.HEMA SAI LAHARI (192311446) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: Y.HEMA SAI LAHARI

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all requirements	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate concepts to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem Solving Approach	20	Logical, well structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct solution with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution

Clarity	10	Clear, well organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand
---------	----	--	--	---------------------------------	--

1. Exploitation of RPC Vulnerabilities in Legacy Windows Servers

Introduction

Remote Procedure Call (RPC) services allow Windows systems to communicate and perform remote operations. In legacy Windows servers, exposed RPC services combined with delayed security patching can create serious security risks. The abnormal traffic and unauthorized connection attempts indicate possible reconnaissance or exploitation attempts.

How Attackers Could Exploit RPC Vulnerabilities

Attackers may first identify systems exposing RPC services through network reconnaissance and vulnerability scanning. If the RPC service contains an unpatched vulnerability, an attacker may send specially crafted requests to the vulnerable service. Depending on the vulnerability, this could result in unauthorized access, denial of service, or remote code execution.

After gaining access, attackers may attempt **privilege escalation** by exploiting weaknesses in the operating system or using compromised credentials. With higher privileges, they could access confidential financial information, modify system configurations, install malicious software, or move laterally to other systems within the organization.

Risk of Delaying Patches

Delaying patches significantly increases risk because known vulnerabilities are often publicly documented and may already have available exploitation techniques. Legacy systems are particularly vulnerable because they may have unsupported software and weak security configurations. In a financial organization, successful exploitation could result in data theft, service disruption, financial loss, and regulatory consequences.

Immediate Patching vs Controlled Maintenance

Immediate patch deployment should be the preferred approach for **critical and actively targeted vulnerabilities**. However, because the organization has operational constraints,

patches should first be tested in a controlled environment. Critical servers can then be patched using a planned maintenance window with backup and rollback procedures.

Mitigation Strategies

- Apply security patches as quickly as operationally possible.
- Restrict RPC services to trusted systems and required network segments.
- Use firewalls and access-control rules to limit unnecessary RPC exposure.
- Segment critical financial servers from normal user networks.
- Monitor RPC traffic and investigate abnormal connection attempts.
- Maintain updated antivirus/endpoint detection solutions.
- Perform regular vulnerability assessments and patch management.
- Maintain reliable backups and tested recovery procedures.
- Use compensating controls when immediate patching is not possible.

Conclusion

The exposed and unpatched RPC services represent a **high security risk**. Immediate risk reduction should begin by restricting exposure and monitoring the affected systems, followed by controlled but urgent patch deployment. This approach provides security while minimizing disruption to business operations.

2. XSS, CSRF and Weak Session Management in a Web Application

Introduction

Web applications handling online transactions must protect user authentication, sessions, and transaction requests. The combination of Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF), and weak session management can allow attackers to compromise accounts and perform unauthorized actions.

How Attackers Could Combine the Vulnerabilities

An attacker may first exploit an XSS vulnerability by injecting malicious script into a vulnerable application page. If the application does not properly validate and encode user input, the script may execute in another user's browser.

If session management is weak, such as using predictable session identifiers, failing to expire sessions, or storing session information insecurely, an attacker may be able to hijack an authenticated session. The compromised session can then be used to access the victim's account.

CSRF can further allow an attacker to trick an authenticated user into unknowingly sending a transaction request. When combined with XSS and poor session controls, these weaknesses can significantly increase the attacker's ability to perform unauthorized operations.

Risks of Poor Session Handling and Input Validation

Poor session management can lead to **session hijacking, account takeover, unauthorized transactions, and privilege abuse**. Lack of input validation allows malicious content to enter the application and increases the possibility of XSS and other injection attacks.

For financial applications, these vulnerabilities can result in financial loss, exposure of personal information, loss of customer trust, and reputational damage.

Need for Layered Security

A single security mechanism cannot protect the application against all attack techniques. A layered security approach combines secure coding, authentication, session protection, input validation, browser security controls, monitoring, and network security.

Mitigation Strategies

- Validate and sanitize all user-supplied input.
- Apply context-appropriate output encoding to prevent XSS.
- Implement Content Security Policy (CSP).
- Use CSRF tokens for state-changing requests.
- Use secure, random, and unpredictable session identifiers.
- Enable Secure, HttpOnly, and appropriate SameSite cookie attributes.
- Regenerate session IDs after authentication.
- Implement session timeout and logout mechanisms.
- Use strong multi-factor authentication for sensitive operations.
- Apply server-side authorization checks.
- Conduct regular vulnerability assessments and penetration testing.
- Monitor suspicious login and transaction activity.

Conclusion

The combination of XSS, CSRF, and weak session management creates a **high-risk environment** for an online transaction system. A layered security architecture with secure input handling, protected sessions, CSRF defenses, strong authentication, and continuous monitoring is essential.

3. Unpatched IIS Server and Risk of Remote Code Execution

Introduction

Internet Information Services (IIS) is widely used to host web applications and services on Windows systems. An outdated IIS server containing critical unpatched vulnerabilities can become a major entry point for attackers, especially when it is accessible from external networks.

Possible Attack Path

Attackers may begin by identifying the IIS version, exposed applications, ports, and services. They can then compare the discovered configuration with known vulnerabilities. If a critical vulnerability exists, attackers may send specially crafted requests to exploit the vulnerable service.

Successful exploitation could potentially allow unauthorized access or remote code execution, depending on the vulnerability. After gaining access, attackers may attempt privilege escalation, install malicious software, steal credentials, access application data, or move to other systems.

Risks of Delaying Security Updates

Delaying security updates leaves known weaknesses available for exploitation. The risk becomes more serious when the server is externally accessible and hosts sensitive applications. Possible consequences include data breaches, website compromise, ransomware, service disruption, financial losses, and reputational damage.

Immediate Patching vs Temporary Isolation

For critical vulnerabilities, **immediate remediation is preferable**. If immediate patching cannot be performed safely because of business dependencies, temporary isolation should be implemented as a compensating control.

The affected IIS server can be restricted using firewalls, network segmentation, access-control rules, or a reverse proxy while a tested patch deployment is prepared. This reduces exposure without unnecessarily stopping the entire business service.

Strategies for Security and Availability

- Test security updates in a staging environment.
- Maintain current backups before patch deployment.
- Use planned maintenance windows.
- Apply patches according to vulnerability severity.
- Temporarily isolate vulnerable servers when patching is delayed.
- Restrict external access to only required services.

- Use web application firewalls where appropriate.
- Monitor IIS logs and network traffic for suspicious activity.
- Remove unnecessary services and applications.
- Maintain a documented rollback and disaster recovery plan.
- Establish a formal vulnerability and patch management process.

Conclusion

An outdated IIS server with critical vulnerabilities represents a **high security risk**, particularly when externally accessible. Immediate patching should be prioritized, while temporary isolation and access restrictions should be used when operational constraints prevent immediate updates. This provides a balance between security and service availability.

4. Plaintext Mobile Storage and Unsecured Communication

Introduction

Mobile applications frequently handle sensitive information such as credentials and personal data. Storing this information in plaintext and transmitting it through unsecured communication channels exposes users and organizations to serious privacy and security risks.

Exploitation Through Device Compromise

If a mobile device is compromised through malware, unauthorized access, rooting, or another security weakness, an attacker may inspect application storage. Plaintext credentials and personal information can then be directly exposed.

Attackers may also use stolen credentials to access the user's account or other services where the same password has been reused.

Exploitation Through Network Interception

When communication occurs over an unsecured channel, attackers on an untrusted network may intercept transmitted information. This can expose login credentials, personal information, session information, or application data.

A **man-in-the-middle (MITM)** attack may allow an attacker to observe or potentially manipulate communication if proper encryption and certificate validation are absent.

Impact on Privacy and Reputation

The exposure of personal information can lead to identity theft, account compromise, financial losses, and privacy violations. For an organization, a data breach can cause customer distrust, reputational damage, regulatory consequences, and financial losses.

Need for Encryption

Encryption protects information by converting readable data into a form that cannot be easily understood by unauthorized parties. Sensitive information should be encrypted both **at rest** and **in transit**.

Secure Storage and Communication Techniques

- Never store passwords or sensitive information in plaintext.
- Use secure platform-provided storage mechanisms such as Android Keystore or iOS Keychain.
- Encrypt sensitive local data when storage is required.
- Use HTTPS with modern TLS for all network communication.
- Properly validate server certificates.
- Avoid transmitting sensitive information over HTTP.
- Use short-lived authentication tokens where appropriate.
- Protect authentication tokens from unauthorized access.
- Apply secure session management.
- Minimize the amount of sensitive data stored on the device.
- Implement secure logout and credential revocation mechanisms.
- Conduct regular mobile application security testing.

Conclusion

Plaintext storage and unsecured communication create a **high risk of data exposure and account compromise**. Strong encryption, secure device storage, HTTPS/TLS, certificate validation, and secure authentication mechanisms are essential to protect user privacy and maintain organizational trust.

5. Windows Firewall Disabled and Unauthorized Access Attempts

Introduction

A Windows firewall acts as an important security barrier by controlling network traffic entering and leaving a system. Temporarily disabling it for troubleshooting can expose critical services if it is not re-enabled promptly.

How Attackers Could Exploit the Exposure

When the firewall is disabled, network services that would normally be restricted may become reachable. Attackers can discover exposed services through network scanning and identify services that may have weak configurations or vulnerabilities.

If a vulnerable service is accessible, attackers may attempt unauthorized authentication, exploit software vulnerabilities, or gain access using compromised credentials. Once access is obtained, they may attempt privilege escalation, install malware, steal data, or move laterally through the network.

Risks of Mismanaging Security Controls

The main problem is not only the temporary firewall change but the lack of control over the change. Leaving the firewall disabled creates an unnecessary attack window.

Possible consequences include unauthorized access, malware infection, data leakage, service compromise, and lateral movement. In an enterprise environment, one compromised system can potentially become a starting point for attacks against other systems.

Importance of Automated Policies

Security controls should not depend entirely on administrators remembering manual changes. Automated policies can detect and correct insecure configurations.

For example, centralized security management can enforce firewall policies and generate alerts whenever a firewall is disabled. Endpoint management solutions can also ensure that required security configurations are continuously maintained.

Administrative Safeguards

- Use centralized firewall policies and configuration management.
- Apply the principle of least privilege to administrative accounts.
- Require approval for security-control changes.
- Record and audit firewall configuration changes.
- Configure alerts when the firewall is disabled.
- Automatically restore approved firewall policies.
- Use separate administrative accounts for privileged tasks.
- Define time limits for temporary configuration changes.
- Document troubleshooting procedures.
- Conduct regular security audits.
- Monitor network traffic and unauthorized connection attempts.
- Train administrators on secure change-management procedures.

Conclusion

Disabling the Windows firewall without restoring it creates a significant security exposure. Automated enforcement, centralized management, monitoring, change control, and administrator accountability can prevent similar incidents. Security controls should remain

active by default and temporary exceptions should be strictly controlled and automatically reverted whenever possible.